

4.0 Risk Management

4.1 DEFINITION AND PURPOSE

Incorporating an Information Security Management System (ISMS) into the operational fabric of Shameless necessitates a cornerstone emphasis on risk management. This systematic and structured approach underpins the organization's efforts to safeguard its most vital assets against an ever-evolving array of cyber threats. At its core, the risk management (RM) process involves identifying, assessing, evaluating, and mitigating potential risks that could compromise the confidentiality, integrity, and availability (CIA) of the organization's information assets. The importance of having a risk management process is multifold; it serves not only as a protective measure but also as a strategic tool that enables Shameless to operate efficiently, maintain its competitive edge, and comply with regulatory and legal requirements.

The integration of the Plan-Do-Check-Act (PCDA) cycle into the risk management process is instrumental in fostering an environment of continuous improvement. This iterative process begins with the:

- **Plan** phase, where Shameless sets the context for risk management, including establishing risk criteria and conducting comprehensive risk assessments. This phase lays the groundwork for identifying and analyzing risks, which in turn informs the development of risk treatment plans.
- The **Do** phase sees implementing these plans and applying targeted strategies and controls to mitigate identified risks efficiently.
- During the **Check** phase, Shameless will engage in ongoing monitoring and review of the risk management process and the effectiveness of the implemented controls. This critical evaluation ensures that risk mitigation efforts are aligned with the organization's security objectives and are effectively reducing risk to acceptable levels.
- Finally, the **Act** phase involves taking corrective and preventative actions based on insights gained from the monitoring activities, aimed at refining and enhancing the risk management process.

Compliance with ISO 27001 Clauses 6.1.2 and 6.1.3a is central to ensuring that Shameless's risk management process is robust, systemic, and aligned with best practices in information security. These clauses mandate the establishment of a comprehensive framework for identifying, analyzing, and treating information security risks, including setting clear risk criteria, conducting consistent risk assessments, and selecting appropriate risk treatment options based on assessment results. By adhering to these standards, Shameless ensures its risk management process is capable of protecting against threats to information security, while also being flexible and adaptable to the changing risk landscape. More information on ISO 27001 clausal adherence is available in subsection 4.5.

A risk management process is crucial for several reasons. It provides a proactive approach to identifying potential risks and vulnerabilities before they can impact the organization, enabling timely and effective risk mitigation strategies. Furthermore, a structured RM process helps prioritize risks based on their potential impact on the organization, ensuring that resources are allocated efficiently to address the most critical threats. Moreover, it supports regulatory compliance, reducing the likelihood of legal and financial penalties associated with data breaches and other security incidents. Ultimately, having an RM process in place not only protects Shameless' valuable information assets but also supports its strategic goals, resilience, and long-term success in the face of cybersecurity challenges.

4.2 METHODOLOGY AND APPROACH

Methodology:

- Identify assets and potential threats and vulnerabilities associated with them.
- Assess the likelihood and impact of each identified risk, considering existing controls
- Assign weighted scores to each risk based on its likelihood, impact, and the effectiveness of existing controls.
- Prioritize risks based on their weighted scores, criticality, and potential impact on the organization or project
- Develop and implement risk treatment strategies to mitigate or eliminate high-priority risks.
- Regularly monitor and review the risk register, updating it as new risks emerge or existing risks change. Adjust risk treatment strategies accordingly.

Approach:

Identify assets and classify them with the following details:

- Criticality (color): This column could indicate the criticality level of each risk using a color scheme
- Asset ID: A unique identifier for each asset within the organization
- Description: A brief description of the asset associated with the risk
- Weighted Score: A score that combines impact and likelihood of risk occurring
- Asset Value: The estimated value or importance of the asset to the organization
- Threat: The potential source of harm or adverse event that could exploit vulnerabilities in the asset
- Vulnerability 1: The first vulnerability associated with the asset
- Vulnerability 1 Explanation: A detailed explanation of the first vulnerability
- Vulnerability 1 Likelihood: The likelihood of the first vulnerability being exploited
- V1 Current Control: Current control measures in place to mitigate the first vulnerability
- V1 Current Control %: The effectiveness of the current control measures in percentage

- Uncertainty Value: Assessment of the uncertainty surrounding the risk estimation for the second vulnerability
- V2 Risk Rating: The risk rating associated with the second vulnerability, considering likelihood and impact
- Overall Risk Rating: The overall risk rating for the asset, considering all identified vulnerabilities
- Risk Treatment Strategy: Proposed strategies or actions to manage or mitigate the identified risks
- Recommended Control: Specific control measures recommended to address the identified risks
- ISO 27001 Control: Identification of controls from the ISO 27001 standard that can be applied to mitigate the identified risks

We chose to use NIST overall due to its comprehensive framework and widespread adoption in the cybersecurity industry. NIST provides a robust set of guidelines and standards for managing and securing information systems.

For controls and certain risk management aspects, we opted to utilize ISO (international organization for Standardization) standards, pertaining to the ISO section 5, 6, 7, and 8 standards. These standards are associated with Leadership, Planning, Support, and Operation. ISO standards offer a globally recognized framework for establishing, implementing, maintaining, and continually improving an information security management system. ISO's focus on controls and risk management complements NIST's broader approach, allowing for a more nuanced and thorough cybersecurity strategy.

Comparatively, OCTAVE is a risk assessment methodology developed by the CERT coordination center at Carnegie Mellon University. While OCTAVE offers a structured approach to identify and prioritize information security risks, it may not provide the same level of comprehensive guidance as NIST or ISO.

NIST benefits Shameless the most due to its thoroughness, credibility, and alignment with industry best practices. Shameless has cited poor network security protocols and internal network management. NIST's extensive documentation provides a utility of training and protocol resources to improve Shameless's network security and detailed guidance on various aspects of cybersecurity from risk management to incident response.

4.3 INTERNAL AND EXTERNAL FACTORS AFFECTING RISK

Based upon our investigation of Shameless' processes and procedures, we have determined that many different factors impact the risk of assets. Following our interview sessions with staff and

personnel, numerous components of the current system can lead to company losses. Below is a list of internal and external factors we have determined to be important when considering risk:

Internal Factors:

- **Lack of Employee Training**
 - The Senior Talent Advisor at Shameless has cited a lack of employee training protocols. Current strategies include sharing “unrelated YouTube videos” along with no formal phishing training.
 - Shameless has cited the infiltration of the “Emotet” malware due to phishing attacks sent to higher-level management. Furthermore, the personal information of over 1000 clients was uploaded to Reddit due to a phishing email. Data is a very important asset Shameless has to monitor to allow for successful business operation.
- **Outdated Systems and Services**
 - The Network Manager at Shameless has explicitly stated the lack of updated network components. It was claimed that the firewalls can’t function due to being out of date and unsupported. The email server being run is from 2013 while the Windows system being used is from 2012. Multiple vulnerabilities and exploits are available online, giving hackers the ability to freely compromise systems with ease.
 - Shameless has directly cited the “increase in application-layer attacks that are breaching the organization’s firewalls.” Furthermore, recent losses of data were directly correlated “to hardware failure.” It is known that these issues in outdated systems have led to direct company losses, and we will continuously work to improve this infrastructure.
- **Lack of Incident Response**
 - A Help Desk and Operations Operative employee explained how they are supposed to be in charge of incident response, but cites the non-existence of a system. A ticketing system was mentioned as a possibility to help determine attacks and resolutions. This would substantially help mitigate future threats and exploits.
 - Numerous attacks have been cited by Shameless, but exploit methods can’t be determined to a certainty. It can only be assumed what got attacked and how. This lack of incident response doesn’t allow for proper remediation efforts. With a proper system put in place, the risk for future attacks will decrease and proper business operations can continue

External Factors:

- **Cyber Threat Landscape**

- The main external factor impacting the risk of assets is the growing threat of hackers and cybercriminal organizations. A study conducted by Duke University has concluded that nearly ~80% of U.S. businesses have been successfully hacked “in an attempt to steal, change or make public important data.” Furthermore, it was cited that these attacks occurred as a “direct result of fewer resources being dedicated to data security at these firms.” Based upon our investigation, we have determined that Shameless is at a high risk from these attacks.
- **Reputational Risks**
 - The perception of Shameless among its stakeholders plays a crucial role in shaping the company's reputation and brand image. Negative publicity resulting from cybersecurity incidents, data breaches, or privacy violations can tarnish Shameless' reputation and impact stakeholder trust, leading to financial losses and diminished market competitiveness.
 - Shameless has cited the loss of personal information that was leaked to the public. It was only discovered after being released on social media. This can seriously damage reputation and potentially turn away prospective customers. Not only this, but employees may feel unsafe with the data they share with the company. This can lead to them potentially leaving the company, causing disruption in business processes.
- **Regulatory Compliances**
 - Shameless has to follow specific data protection regulations based on the company's location. This includes the GDPR, the CPRA, the PCS DDI, and the DPDPA. More information about these regulations can be found above under section 3.8. Potential fines can easily range in the millions, and following the data leaks and lack of protocols, Shameless gives an easy case for policy enforcers.
 - Each of these regulations requires proper controls and their implementations. Shameless currently lacks any of these. We will work continuously to ensure that your company is properly aligned with all these requirements, diminishing the risk of unnecessary punishments and financial losses.

4.3.1 QUANTITATIVE VS. QUALITATIVE RISK CONTROL

Quantitative risk control involves the use of numerical data and statistical techniques to quantify and analyze risks in terms of actual values/estimates, financial impact, and other measurable parameters. By quantifying risks in terms of probabilities and numerical values, organizations can make informed decisions about risk management. For example, Shameless has a lack of training towards social engineering schemes. A quantitative approach to assessing risk would be to initially quantify the amount of employees falling for these attacks. Following the implementation of a training process, the same results would be recorded and then compared to the previous assessment. This would provide a

quantifiable result that could be easily compared.

Qualitative risk control focuses on assessing and managing risks based on subjective criteria, such as likelihood, impact, and severity. It involves identifying potential risks, analyzing their characteristics, and prioritizing them based on their perceived significance to the organization. Qualitative approaches allow for flexibility in risk assessment and management, enabling organizations to adapt to changing circumstances and emerging threats. For example, Shameless has numerous assets with different levels of importance to the company's operations. These assets can be defined to align with the current interests of Shameless, allowing for prioritization and significance based on what the business needs.

By integrating quantitative and qualitative approaches, Shameless can develop a comprehensive risk management framework that enhances its resilience to external threats while improving decision-making processes. Quantitative methods can provide insights into the likelihood and financial impact of specific risk scenarios, such as data breaches and hardware disruptions. Qualitative methods can help Shameless prioritize risks, identify key vulnerabilities, and communicate with stakeholders. This approach would be beneficial for addressing subjective factors such as regulatory compliance requirements and public perception.

4.4 PURPOSE AND DESIGN OF RISK REGISTER

The risk register is an addition to the asset register provided in conjunction with this report and described in greater detail in section 3.0 above. Its primary purpose is to provide a holistic view of your organization's information security posture. It also helps create a structured, systematic approach to identifying, assessing, and controlling risks associated with your assets. Most importantly, the risk register for your assets is intended to be consistently revisited and updated to reflect improvements in reducing your assets' risks.

Currently, Shameless has no systemized approach to identify and assess threats and vulnerabilities of its information assets. Gill Ltd. has designed a risk register with Shameless' needs in mind. From our interview sessions with the staff of Shameless, we discovered that there is no system in place to prioritize projects which often leads to the oversight of major issues relating to information security. While the risk register is not a task prioritization system itself, it is an effective starting point for determining which major risks should be addressed most immediately.

Due to the importance of your organization being able to repeat the RM process within the risk register, the subsections below provide greater detail on how to make use of this.

4.4.1 IDENTIFYING AND DESCRIBING RISKS

A risk is the potential for loss if a threat to an asset is acted upon. For example, Shameless does not have a data backup policy, so if the database experiences downtime, the risk of data loss is high. Descriptions of risk for each asset category outlined in the asset register are as follows:

- **People:** Risks to employees include human error, unauthorized access, or other internal threats. Employees can compromise the CIA of an organization's assets.
- **Procedures:** Risks of procedures encompass inadequate or outdated policies. Weak policies can leave an organization unprepared to respond to incidents and leave its systems open to unauthorized access and data theft.
- **Data:** Risks related to data include data breaches, loss, and leakage especially if proper security measures are not in place.
- **Software:** Risks of software include unpatched applications/programs that could be exploited, thus compromising the stability of an organization's IT infrastructure.
- **Hardware:** Risks associated with hardware relate to physical theft or unauthorized access to physical devices containing sensitive data.
- **Networking Components:** Risks of networking components include outdated or unsecured routers, servers, and firewalls that leave the network open to attackers or more susceptible to downtime and thus lost revenue.

All of the risks above have the potential to cause significant loss (both financial and reputational) to your organization, so it is important to have an organized risk register and RM process so that you can 1) identify and assess the criticality of risks associated with certain assets, and 2) implement effective controls to reduce the risk.

The risk register our team is providing lays out a quantitative approach to assessing each asset's risk. To use the risk register, all assets from the asset register are combined onto a separate spreadsheet with each asset in its own row. Begin the risk assessment process for an asset by multiplying the "weighted score" of the asset from the asset register by 20 to create a risk-rating scheme on a 100 scale. This will make distinguishing between levels of risk criticality easier for your organization. Risk is ultimately determined by the asset value and the likelihood of the threat occurring. See the table below for an example of how to start the risk register.

Asset ID	Description	Weighted Score	Asset Value
----------	-------------	----------------	-------------

HW-100	Company/Personal Laptop	3.0	60 (3.0 x 20)
--------	-------------------------	-----	---------------

Figure 3 - Risk Register asset value determination

4.4.2 IDENTIFYING THREATS AND VULNERABILITIES

The first step in the RM process is to identify the risk of a given information asset. This involves the recognition, enumeration, and documentation of risks which begins in the risk register. Given that a risk is the potential of a certain threat's vulnerability being exploited, these two factors—threats and vulnerabilities—are what is enumerated in the risk register.

A threat is the potential for an attack to occur. For information assets in the risk register, identify threats by determining an event that either has occurred within the past year, or that could occur in the future given its vulnerabilities. A threat is more likely to occur if it is not protected or mitigated against. Typically, threats to information assets can be classified as one of the following (also as seen in the provided risk register):

- Compromises to Intellectual Property
- Unauthorized Trespass
- Forces of Nature
- Human Error or Failure
- Information Extortion
- Deviation in Quality of Service

A vulnerability is an exploitable weakness of a certain threat. To identify a vulnerability of a certain threat, assess the asset for flaws that could be exploited to compromise information security. See the table below for the continued example from Figure 3 for identifying a threat and vulnerability in the risk register.

Threat	Vulnerability	Vulnerability Explanation
Information Extortion	Weak data protection measures	Lack of encryption and strong password policies make company devices more susceptible to data theft.

Figure 4 - Threat and Vulnerability Identification in the Risk Register

If controls are not put in place to protect against an asset's vulnerabilities, the CIA of the organization's systems can be compromised. For example, in Figure 4 above, if weak

data protection measures are taken advantage of on a company laptop, sensitive data could be stolen which compromises all three pillars of CIA.

4.4.3 DETERMINING LIKELIHOOD OF A THREAT

In the context of RM, the likelihood of a threat is a rating of the probability of a specific vulnerability being exploited. The risk register provided by Gill Ltd. uses a quantified scale to rank the likelihood of a threat event occurring:

Likelihood	Description	% Likelihood of Occurrence within 12 Months
0.0	Not applicable	0%
0.2	Rare	5%
0.4	Unlikely	25%
0.6	Moderate	50%
0.8	Likely	75%
1.0	Certain	100%

Figure 5 - Threat likelihood ranking scheme

From the information Gill Ltd. gathered during staff interviews and consulting observations, our team determined most of Shameless' assets to be either likely or certainly impacted by a threat event within the next 12 months. Continuing with the asset example from Figures 3 and 4, the vulnerability of "weak data protection measures" is given a likelihood value of 1.0 due to the fact that Shameless currently does not have any data protection measures in place which has already resulted in compromises to its data's CIA.

Ultimately, the determination of the likelihood of a threat is at the discretion of the organization, but it should still be made on sound judgment and available evidence.

4.4.4 CLASSIFYING IMPACT OF A THREAT

The overall impact of a threat is how your organization can distinguish between the criticality of each threat and thus prioritize controls for the most critical. Gill Ltd. made this a quantified approach in which the risk rating of two (2) vulnerabilities for each asset threat are averaged.

Five factors go into calculating the risk rating of each vulnerability: asset value (detailed in section 4.4.1), vulnerability likelihood (detailed in 4.4.3), vulnerability current control, the percent value of the control, and the percent value of uncertainty. A current control is

anything currently in place that protects the security of the asset, such as employee training, or a firewall. The control is then quantified into a percentage which is determined by the organization. If there is no control, the percentage value will be 0%. Gill Ltd. determined some controls, like the existing firewall, to be 5%, because while its function is to provide protection, its current state is ineffective. Complete protection would be 100%. Uncertainty value takes into account the unknowns which could include gaps of knowledge, or estimation errors of the control value.

Taking these factors into account, the formula Gill Ltd. used to determine the risk of a vulnerability follows, as does a representation of this in the risk register:

$$(Likelihood \times Value) - (Control \% \times Value) + (Uncertainty \% \times Value) = Risk$$

Asset Value	Vuln. Likelihood	Vuln. Current Control	Vuln. Control %	Uncertainty Value	Vuln. Risk Rating
60	1.0	None	0%	15%	69.0

Figure 6 - Risk rating system for risk register

While the above is calculated for only one vulnerability, the second vulnerability for this asset was given a risk rating of 50.4. Averaged out, the overall risk of this asset is 59.7. See the table below for where this rating would stand regarding criticality.

Rank	Description	Example
0-10	No applicable threat	No impact
10-20	Insignificant (Accepted Risk Level)	No interruption, no exposed data
20-40	Minor	Multi-minute interruption, no exposed data
40-60	Moderate	Multi-hour interruption, minor exposure of data. System disruption would cause a moderate problem to the organisation and possibly other networks or systems
60-70	Major	One-day interruption, exposure of data
70-100	Severe	Multi-day interruption, major exposure of sensitive data. Damage / disruption to the system would cause the most impact on the organisation, mission, and other networks and systems

Figure 7 - Risk criticality rating scale

Color coding based on risk rank helps to identify which assets pose the greatest risk and potential impact to your organization.

4.5 RISK TREATMENT STRATEGIES

- Mitigation: Implement measures to reduce the likelihood or impact of the risk. This could involve strengthening security controls, improving processes, or enhancing training and awareness programs
- Defense: Implement measures to stop and completely prevent a risk from occurring
- Training and Awareness: Invest in employee training and awareness programs to educate staff about potential risks, their consequences, and how to prevent or respond to them effectively
- Compliance: Ensure compliance with relevant laws, regulations, and industry standards to mitigate legal and regulatory risks.
- Investment in Technology: Deploy advanced technologies and tools to enhance security, detect potential risks, and automate risk management processes
- Improvement of Controls: Enhance existing controls or implement new controls to address vulnerabilities and reduce the likelihood or impact of risks.

ISO 27001 Controls 6.1.2 - Information Security Risk Assessment 6.1.3 - Information Security Risk Treatment	Related Document Section
6.1.2a - establishes and maintains information security risk criteria that include: 1. The risk acceptance criteria; and 2. Criteria for performing information security risk assessments	3.7.3, 4.3.1, 4.4
6.1.2b - ensures that repeated information security risk assessments produce consistent, valid and comparable results	4.4
6.1.2c - identifies the information security risks: 1. Apply the information security risk assessment process to identify risks associated with the loss of confidentiality, integrity and availability for information within the scope of the information security management system; and 2. Identify the risk owners	4.3
6.1.2d - analyses the information security risks:	4.3

1. Assess the potential consequences that would result if the risks identified in 6.1.2 c) 1) were to materialize; 2. Assess the realistic likelihood of the occurrence of the risks identified in 6.1.2 c) 1); and 3. Determine the levels of risk	
6.1.2e - evaluates the information security risks: 1. Compare the results of risk analysis with the risk criteria established in 6.1.2 a); and 2. Prioritize the analyzed risks for risk treatment	4.3
6.1.3a - select appropriate information security risk treatment options, taking account of the risk assessment results	See risk register columns V, W, and X